

Reconnaissance: Passive & Active

Passive recon (no target contact)

DNS: whois, dig/nslookup, SPF/DMARC, subdomain brute-listing

Search engines: Google dorking ("filetype:pdf site:company.com")

Shodan/Censys: exposed services by org IP space

OSINT social: LinkedIn employees, GitHub repos, job listings (stack hints)

Certificate transparency logs (crt.sh) – subdomains revealed by TLS certs

Breach databases: haveibeenpwned-style leaks (pwned data)

Active recon (methods that touch the target)

Ping sweeps (fping, nmap -sn)

Port scans

Banner grabbing (nc, scripts)

Web enumeration: robots.txt, sitemaps, headers, tech fingerprint (whatweb)

API enumeration: open endpoints, versioned paths

Google dorking power

```
site:example.com filetype:sql
site:example.com intitle:"index of" (directory listing)
inurl:admin inurl:login
"password" filetype:log site:example.com
```

Defense angle (what blue teams want you to think)

Web server errors reveal stack → strip details

Directory listings → disable

Unnecessary open ports → firewall

Subdomains → wildcard certs and monitoring

Published GitHub secrets → secret scanning + rotation

Every byte of recon shrinks the exploitation phase. A thorough mapper finds the seam before the big hammer is needed.

[← The Penetration Testing Life...](#)

[Scanning, Exploitation & Post-...](#)